



**המכללה האקדמית תל אביב יפו
בית הספר למערכות מידע**

**אבטחת מידע ממוחשב - סייבר, 272035
ד"ר יצחק אביב
תשפ"ג, סמסטר א', מועד א', 17/02/2023**

--	--	--	--	--	--	--	--	--

מספר זהות:

**משך הבחינה: שעתיים
ללא חומר עזר**

בבחינה 20 שאלות, יש לענות על כולן. משקל השאלות זהה - 5 נקודות לשאלה.
בכל שאלה יש לסמן את התשובה הנכונה ביותר (אחת בלבד).

בהצלחה!



שאלה מס' 1 (5 נק')

מהי הגדרה המתאימה ביותר למושג "מרחב הסייבר - Cyber Space" מתוך ההגדרות הבאות:

- א. כלל רכיבי רשת (נייחת ואלחוטית) בעולם, כלל הרכיבים הדיגיטליים המחוברים לרשת האינטרנט העולמית או לרשתות פנימיות בארגונים (גם כאלה אשר חסומות לגישה חיצונית), כל האנשים והארגונים הפועלים במרחב הדיגיטלי.
- ב. כלל רכיבי רשת (נייחת ואלחוטית) בעולם, כלל הרכיבים הדיגיטליים בעולם המחוברים באמצעות רשת אינטרנט, כל רשתות הפנים הארגוניות שמחוברות לרשת האינטרנט, כל האנשים והארגונים הפועלים במרחב הדיגיטלי.
- ג. אוסף של כלל הרכיבים בעלי כתובות IP המחוברים לרשת האינטרנט העולמית לרבות רשתות נייחות, סלולאר, לוויין, RF.
- ד. כלל הרכיבים שניתנים לתקיפה במרחב הסייבר מייצרים אקו-סיסטם של מרחב הסייבר.

שאלה מס' 2 (5 נק')

בחרו בהגדרה המתאימה ביותר לנוזקה (Malware):

- א. זוהי הגדרה גנרית, המאפיינת תוכנה זדונית שמטרתה לשבש את הפעילות התקינה של הרשתות והמערכות אשר מותקפות ופועלות במרחב הסייבר.
- ב. זוהי הגדרה גנרית, המאפיינת תוכנה זדונית שמטרתה לשבש פעילות תקינה של רשתות תקשורת המותקפות ופועלות במרחב הסייבר.
- ג. זוהי הגדרה ספציפית, המאפיינת תוכנה זדונית שהנה דורשת שרת אירוח (Host Based) שמטרתו לשבש פעילות תקינה של מערכות המותקפות ופועלות ברשתות פנימיות וחיצוניות של הארגון.
- ד. זוהי הגדרה ספציפית, המאפיינת תוכנה זדונית שמטרתה לשבש פעילות תקינה של מערכות המותקפות ופועלות ברשתות פנימיות של הארגון.

שאלה מס' 3 (5 נק')

מהו ההבדל העיקרי בין וירוס (Virus) לתולעת (Worm):

- א. וירוס דורש הפעלה של קובץ או תוכנה נגועים, בעוד שהתולעת מפיצה את עצמה בצורה עצמאית.
- ב. וירוס תוקף בעיקר את הרשתות הפנימיות של החברה, בעוד שהתולעת תוקפת את הרשתות החיצוניות של חברה.
- ג. וירוס תוקף באופן ממוקד את מערכות המחשב, בעוד שהתולעת תקופת את הרשת.
- ד. כל התשובות נכונות.

שאלה מס' 4 (5 נק')

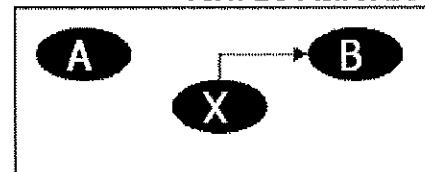
מהו תפקידו של Dropper בעת תקיפת רשת ארגונית

- א. תכנת Dropper איננה גורמת נזק באופן ישיר למערכת, אלא הפעלת Dropper גורמת להורדת והתקנת תכנה זדונית, אשר מאפשרת יצירת שליטה וקשר עם התוקף ואת ההשתלטות מרחוק על המערכת (C&C).
- ב. תכנת Dropper איננה גורמת נזק באופן ישיר למערכת, אלא הפעלת Dropper במסגרת תקיפת ransomware גורמת להצפנת דיסק זיכרון של המחשב הנתקף.
- ג. תכנת Dropper גורמת נזק באופן ישיר למערכת, באמצעות שיבוש הפעילות התקינה של המערכת, והאטת משאבי המערכת.
- ד. תכנת Dropper גורמת נזק באופן ישיר למערכת, באמצעות שיבוש הפעילות התקינה של הרשת, והאטת משאבי הרשת.



שאלה מס' 5 (5 נק')

לפניכם סרטוט המתאר טופולוגיה שבה שני רכיבים ברשת תקינה (A ו-B) מקיימים שיח באופן תדיר. רכיב X הנו רכיב זדוני.



בחרו בתשובה המתאימה ביותר לסוג התקיפה שרכיב X מבצע לפי הסרטוט:

- זוהי תקיפה אקטיבית, המבוססת על התחזות של התוקף לרכיב רשת תקין ושליחת מסרים מפוברקים שעשויים להכיל תוכן זדוני.
- זוהי תקיפה פאסיבית, המבוססת על התחזות של התוקף לרכיב רשת תקין ושליחת מסרים מפוברקים שעשויים להכיל תוכן זדוני.
- זוהי תקיפה אקטיבית, המבוססת על השתלטות על סשן (Session) בין רכיב A ורכיב B ושליחת מסרים מפוברקים שעשויים להכיל תוכן זדוני.
- זוהי תקיפה פאסיבית, המבוססת על השתלטות על סשן (Session) בין רכיב A ורכיב B ושליחת מסרים מפוברקים שעשויים להכיל תוכן זדוני.

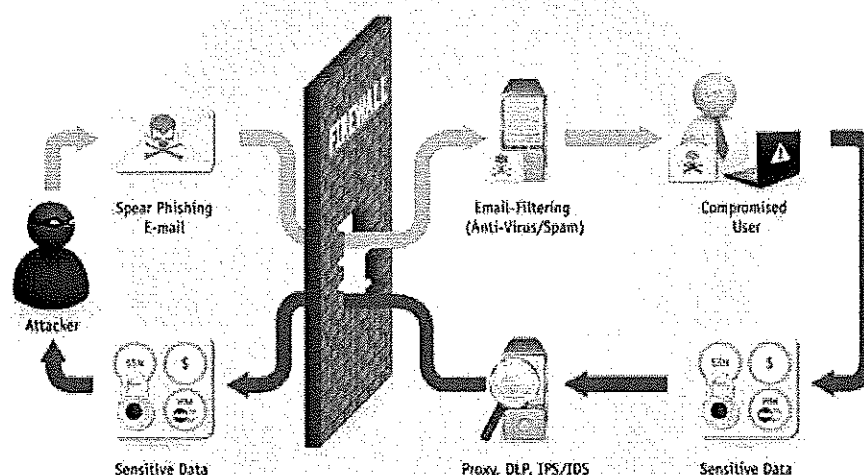
שאלה מס' 6 (5 נק')

ארבעה אימים מרכזיים הם הונאה (Deception), גילוי (Unauthorized Disclosure), תפיסה בכוח (Usurpation) ושיבוש (Disruption). בחרו את סוגי התקיפה אשר מאפיינים את האיום "שיבוש":

- שלילת יכולת, השחתה, חסימה.
- חשיפה, ירוט, הסקה.
- התחזות, זיוף, דחייה.
- ניכוס פסול, שימוש לרעה.

שאלה מס' 7 (5 נק')

לפניכם תרחיש תקיפה. בחרו בתשובה המתאימה ביותר אשר מתארת את התקיפה:

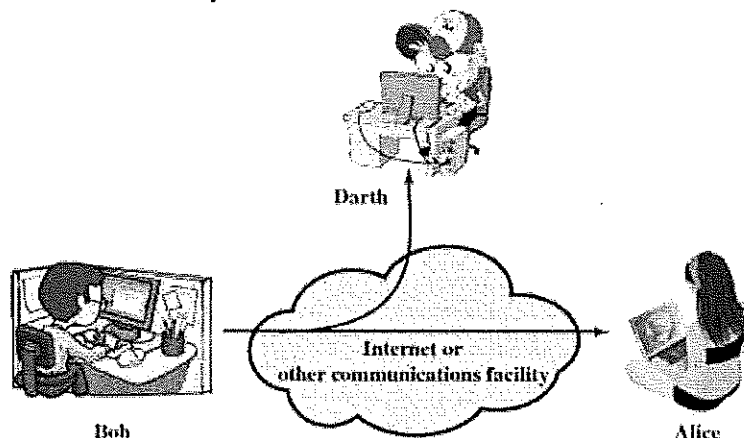


- התרחיש מציג תקיפה שמטרתה חשיפת המידע לתוקף.
- התרחיש מציג תקיפה שמטרתה הצפת המידע על ידי התוקף.
- התרחיש מציג תקיפה שמטרתה זיוף המידע על ידי התוקף.
- התרחיש מציג תקיפה שמטרתה שיבוש המידע על ידי התוקף.



שאלה מס' 8 (5 נק')

לפניכם תרחיש תקיפה. משתמשי Alice ו-Bob מקיימים קשר דיגיטלי לגיטימי, בעוד ש Darth הנו תוקף סייבר. בחרו בתשובה המתאימה ביותר אשר מתארת את התקיפה:



- התרחיש מציג תקיפה פאסיבית, שמטרתה של Darth לייט מסרים העוברים בין Alice ו-Bob.
- התרחיש מציג תקיפה אקטיבית, שמטרתה של Darth לייט מסרים העוברים בין Alice ו-Bob.
- התרחיש מציג תקיפה אקטיבית, שמטרתה של Darth לשבש מסרים העוברים בין Alice ו-Bob.
- התרחיש מציג תקיפה פאסיבית, שמטרתה של Darth לשבש מסרים העוברים בין Alice ו-Bob.

3 השאלות הבאות הן קבוצת שאלות

שאלה מס' 9 (5 נק')

ארגון פיננסי מקיים דיון בתחום הסייבר שבמהלכו מנהלת מרכז ניטור הסייבר בארגון מתלוננת על מערכת IDS שהחברה רכשה, בטענה שרוב ההתראות של המערכת הן התראות שווא ואינן מצביעות על האיום האמיתי. סביר להניח כי מנהלת מרכז ניטור הסייבר תאמר:

- המערכת IDS מתריעה כל היום על False positive, ולכן מקשה מאוד על צוות ניטור הסייבר להתמקד בתחקור אירועי סייבר אמיתיים.
- המערכת IDS מתריעה כל היום על False negative, ולכן מקשה מאוד על צוות ניטור הסייבר להתמקד בתחקור אירועי סייבר אמיתיים.
- המערכת IDS מתריעה כל היום על True negative, ולכן מקשה מאוד על צוות ניטור הסייבר להתמקד בתחקור אירועי סייבר אמיתיים.
- המערכת IDS מתריעה כל היום על True positive, ולכן מקשה מאוד על צוות ניטור הסייבר להתמקד בתחקור אירועי סייבר אמיתיים.

שאלה מס' 10 (5 נק')

כמענה לתופעת התראות שווא, המשתתפים בדיון הציגו שיפורים הדרושים עבור מערכת IDS על מנת לצמצם בכמויות אירועי השווא. בחרו בתשובה המתאימה ביותר, שביכולתה לצמצם באופן משמעותי את הכמויות של התראות השווא.

- להפעיל את המערכת IDS על בסיס מודול שמבוסס חתימות (Knowledge-based IDS) בלבד, ולכבות מודול שמבוסס על זיהוי התנהגותי (Behavior-based IDS).
- להפעיל את המערכת IDS על בסיס מודול שמבוסס על זיהוי התנהגותי (Behavior-based IDS) בלבד, ולכבות מודול שמבוסס חתימות (Knowledge-based IDS).
- להפעיל את המערכת IDS על בסיס מודול שמבוסס חתימות (Knowledge-based IDS), תוך הפעלת יכולת לזיהוי אנומליות.
- להפעיל את המערכת IDS על בסיס מודול שמבוסס על זיהוי התנהגותי (Behavior-based IDS), תוך הפעלת יכולת לזיהוי אנומליות.



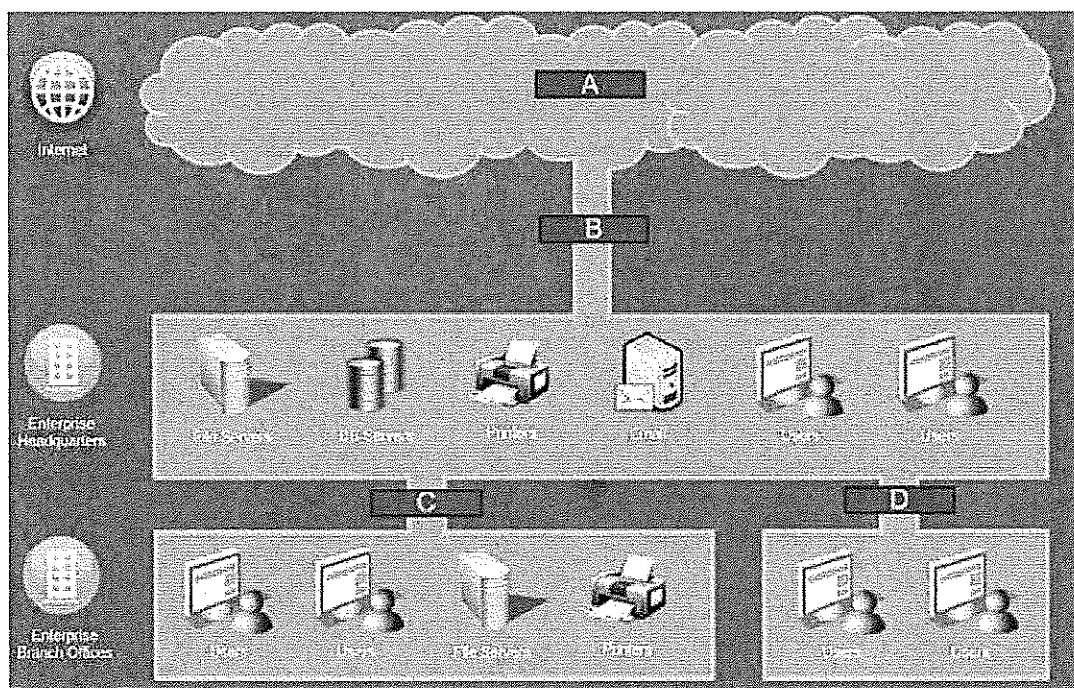
שאלה מס' 11 (5 נק')

במהלך הדיון עלה כי הווריאנט של הנוזקה הידועה והמוכרת מזו שנה בעולם תקפה את הארגון. הנוזקה חדרה לרשת מחשוב ארגונית וגרמה לנזק. בתחקיר עלה כי ספק IDS שחרר עדכון רלוונטי חצי שנה לפני תאריך הפגיעה של הנוזקה ברשת הארגונית, והארגון אכן התקין את העדכון באופן מיידי. על אף התקנת העדכון, ההתראה על הנוזקה שנוצרה במערכת IDS לא הגיעה לטיפול של צוות ניטור סייבר בארגון. משתתפי הדיון נתבקשו להעביר המלצות לשיפור רמת הדיוק של מערך הניטור. ידוע כי שלושה משתתפים בדיון העבירו המלצות לא נכונות שאינן יכולות להתרחש בפעול. בחרו בתשובה אשר מייצגת את ההמלצה הנכונה.

- הווריאנט של הנוזקה סווג על ידי מערכת IDS לרמת סיכון 8, בעוד שההתראות שעולות לצוות הניטור הן מסיווג 12 ומעלה. לאור זאת, ממליץ להעביר את כלל ההתראות מרמת סיכון 8 ומעלה לבחינת צוות הניטור.
- ממליץ לחבר את מערכת ה-IDS למכונת חומת האש בפרימטר הגנתי, על מנת לאפשר הגנה כפולה על הרשת. במידה וה-IDS יפספס את הנוזקה, מכונת חומת האש בפרימטר הגנתי תוכל לאתר את הנוזקה במעגל השני.
- ממליץ לחבר את מערכת ה-IDS למכונת חומת האש בפרימטר הגנתי, על מנת לאפשר הגנה כפולה על הרשת. במידה ומכונת חומת האש בפרימטר הגנתי תפספס את הנוזקה, מערכת IDS תוכל לאתר את הנוזקה במעגל השני.
- תשובות ב' ו-ג' אפשריות.

2 השאלות הבאות הן קבוצת שאלות

ליבת ה-IT של חברת Trust Bank מותקנת ומופעלת מתוך מרכז מחשוב DC פרטי המנותק מרשת האינטרנט. חברת Trust Bank קיבלה אישור רגולטור לחבר את סביבת ה-IT שלה לרשת האינטרנט. לאור דרישות רגולציה סייבר על הארגונים הפיננסיים, החברה החליטה כי המענה הנכון ביותר הוא אימוץ ארכיטקטורת הגנה ריכוזית. לפניכם ארכיטקטורת ליבת ה-IT של החברה וחיבור הצפוי לרשת האינטרנט.



שאלה מס' 12 (5 נק')

בחרו בתשובה המתאימה ביותר לארכיטקטורת הגנה ריכוזית עבור חברת Trust Bank:

- על החברה להשקיע בהקמת פרימטר הגנתי בנקודה B בחיבור של סביבת האינטרנט לרשת הפנימית של החברה.
- על החברה להשקיע בהקמת פרימטר הגנתי בנקודה B בחיבור של סביבת האינטרנט לרשת הפנימית של החברה והן בנקודה A על מנת לפרוס מלכודות דבש ברשת האינטרנט כדי לאתר את התוקפים עוד בטרם הגיעו לרשת הפנימית.
- על החברה להשקיע בהקמת פרימטר הגנתי בנקודה A בחיבור של סביבת האינטרנט לרשת הפנימית של החברה.
- על החברה להשקיע בנקודות B, C, D על מנת להגיע להגנה מקסימלית על הפרמטר הגנתי.



שאלה מס' 13 (5 נק')

מנהלת הגנת המידע הארגוני קיבלה משימה לגבש ארכיטקטורת הגנה היקפית המבוססת פרימטר ריכוזי. ניתן לצפות כי הפתרון יכלול את הרכיבים הבאים:

- א. יש לשלב בפתרון חומת אש, מערכת IDS (Intrusion Detection System) שבפוטנציאל יכולה להתפתח למערך IPS (Intrusion Prevention System), אגטי וירוס, מערכת DLP (Data Loss Prevention).
- ב. יש לשלב בפתרון מערכות EMM (Enterprise Mobility Management) שיקלו לפחות רכיבי MDM (Mobile Device Management) ו-MAM (Mobile App Management).
- ג. יש לשלב בפתרון מערכות מודיעין סייבר וכן פתרונות של מלכודות דבש ברשת הפנימית.
- ד. יש לשלב בפתרון מערכות זהות והזדהות שמבוססות על הצפנה קריפטוגרפית.

שאלה מס' 14 (5 נק')

במרחב הסייבר פועלים קבוצות וארגונים שונים אשר פועלים בכדי לגרום נזק ממטרות שונות. בחרו בתשובה הנכונה:

- א. אחת המטרות של גופים מעצמתיים היא בניית יכולות המאפשרות השבתת תשתיות אזרחיות קריטיות (למשל תשתית חשמל או מים) של מדינת אויב בעת הצורך.
- ב. אחת המטרות של האקטיביסטים היא גניבת מידע לצרכי מכירה ועשיית רווח.
- ג. אחת המטרות של ארגוני טרור היא השבתת תשתיות של מערך בתי הספר העל יסודיים במדינת היעד.
- ד. אחת המטרות של גופי פשיעה בסייבר היא גניבת מידע לצרכי יצירת השפה ותודעה.

שאלה מס' 15 (5 נק')

מה המשמעות של פרימטר ארגוני במערכות מבוזרות, שבו משתמשים ניידים צורכים יישומים ומידע במחשוב קצה נייד בכל מקום בעולם:

- א. הפרימטר הנו מבוזר ולמעשה כל מחשב קצה משמש כפרימטר כניסה לרשת הארגונית.
- ב. הארגון חייב להחזיק מגוון רשתות DMZ עבור כל סוג איום שביחד יבנו פרימטר היקפי בכניסה לרשת ארגונית.
- ג. הארגון חייב לשלב בפרימטר יכולות של אנליטיקת סייבר לטובת התמודדות עם תקיפות מוכרות וידועות.
- ד. גופי מודיעין סייבר מהווים פרימטר קדמי במטרה למנוע התרחשויות אירועי סייבר עוד בשלב התכנון המוקדם של התוקפים.

שאלה מס' 16 (5 נק')

מנהל הגנת מידע ארגוני קיבל תקציב לשדרוג מערך חומת האש בארגון. בהתאם להמלצת צוות יועצים חיצוניים, הוחלט לחזק הגנת המידע הן בנקודת הכניסה הראשית בארגון בפרימטר בשכבת הרשת, והן ברמת השרתים המפעילים את המערכות בארגון התפעוליות. בחרו בתשובה המתאימה ביותר לפתרון אפשרי:

- א. התקציב לשדרוג מערך חומת האש יתחלק ברכש מכונת אש ייעודית (Network based FW) לבין תכנת חומת אש (Host based FW) אשר תתפרס על חלק מהשרתים בהתאם להחלטת אנשי הסייבר בארגון.
- ב. התקציב לשדרוג מערך חומת האש יתחלק ברכש מכונת אש ייעודית (Network based FW) לבין תכנת חומת אש (Host based FW) אשר תתפרס על כלל השרתים המופעלים על ידי הארגון.
- ג. התקציב לשדרוג מערך חומת האש יושקע ברכש מכונת אש ייעודית (Network based FW), שייתן מענה הן לשכבת הרשת והן לשכבת השרתים.
- ד. התקציב לשדרוג מערך חומת האש יושקע ברכש מספר מכונות אש ייעודיות (Network based FW) שיפרסו ברשת ארגונים בנקודות שונות, שייתנו מענה הן לשכבת הרשת והן לשכבת השרתים.



שאלה מס' 17 (5 נק')

מערכות של משטרת מקסיקו פועלות ברשת הפנימית של החברה (Private Network). הרשת הפנימית של משטרת מקסיקו מנוהלת על ידי יחידות ה-IT והסייבר של משטרת מקסיקו. לאור ההחלטה על חיבור מערכת שליטה ובקרה (מערכת Alfa) של משטרת מקסיקו, למערכת שליטה ובקרה של שירות בטחון הכלל של מקסיקו (מערכת Torpedo), על מנהל הסייבר בארגון הוטלה משימת גיבוש הפתרון לחיבור זה. מערכות Alfa ו-Torpedo מופעלות ברשתות הפנימיות של הגופים. יצוין, כי שירות בטחון הכלל של מקסיקו הנו גוף עצמאי שאינו שייך למשטרת מקסיקו. הרשת הפנימית של שירות בטחון הכלל של מקסיקו מנוהלת על ידי יחידות ה-IT והסייבר של שירות בטחון הכלל של מקסיקו. בחרו בתשובה המתאימה ביותר להחלטה שמנהל הסייבר הארגוני של משטרת מקסיקו לאופן חיבור בין רשתות משטרת מקסיקו לבין רשת של שירות הבטחון הכללי של מקסיקו.

א. יש לחבר רשת של שירות הבטחון הכללי של מקסיקו לרשת של משטרת מקסיקו באמצעות שכבת הגנת המידע בפרימטר הגנתי, תוך סינון וזיכוי תוכן קפדני העובר בין שתי הרשתות.

ב. מאחר ושתי הרשתות של הארגונים הן רשתות ממשלתיות, ניתן לחבר בין הרשתות באופן ישיר ללא צורך בשכבת מוצרי הגנת המידע וסייבר.

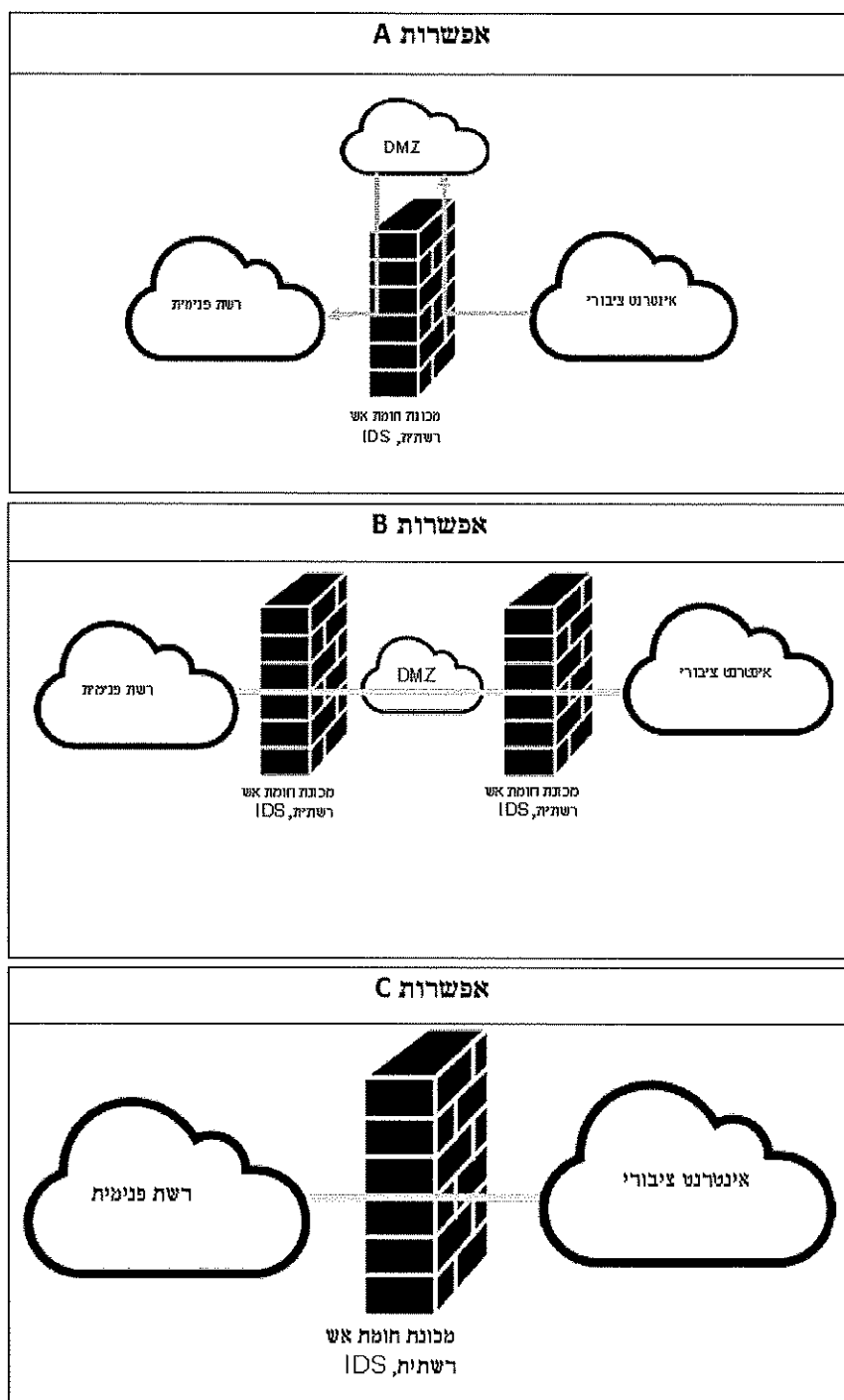
ג. לא ניתן לחבר בין שתי הרשתות, מאחר ויש חשש כי רשת שירות הבטחון הכללי של מקסיקו אינה חסינה לפגיעות סייבר.

ד. לא ניתן לחבר בין שתי הרשתות, מאחר ויש חשש כי רשת משטרת מקסיקו אינה חסינה לפגיעות סייבר.



שאלה מס' 18 (5 נק')

לפניכם שלוש אפשרויות להפרדה בין הרשת הפנימית של הארגון לבין רשת האינטרנט.



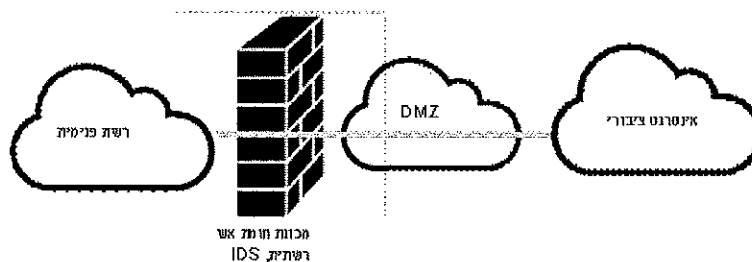
בהנחה שבשלושת האפשרויות הללו ישנם רכיבים זהים ברמת חומת אש, IDS ו-DMZ, איזו אפשרות מספקת מענה הבנה החזק ביותר:

- אפשרות B.
- אפשרות A.
- אפשרות C.
- ניתן להתאים את כל האפשרויות לרמת הגנה זהה.



שאלה מס' 19 (5 נק')

הארגון שוקל לאמץ את החלופה הבאה להגנת הפרימטר:



בחרו בתשובה המתאימה ביותר לסיכוני סייבר של החלופה:

- א. רכיב ה-DMZ פגיע מאחר ואינו מוגן מתקיפות מרשת האינטרנט.
- ב. הרשת הפנימית פגיעה מאחר ולא ניתן להסתמך על DMZ.
- ג. הרשת הפנימית פגיעה מאחר ולא ניתן להסתמך על חומת האש.
- ד. תשובה א' ו-ב' נכונות.
- ה. כל התשובות נכונות.

שאלה מס' 20 (5 נק')

תהליך זהות והזדהות ברשת ארגונית נדרש לבצע עבור רכיבים הבאים:

- א. יש לבצע ניהול והפעלת תהליך זהות והזדהות עבור כלל הרכיבים המחוברים ברשת והמשתמשים הפועלים ברשת.
- ב. יש לבצע ניהול והפעלת תהליך זהות עבור כלל המשתמשים הפועלים ברשת, ותהליך ההזדהות עבור כלל הרכיבים המחוברים ברשת.
- ג. יש לבצע ניהול והפעלת תהליך זהות עבור כלל הרכיבים המחוברים ברשת, ותהליך ההזדהות עבור כלל המשתמשים הפועלים ברשת.
- ד. יש לבצע ניהול והפעלת תהליך זהות והזדהות עבור כלל המשתמשים הפועלים ברשת.